

SIZMA TESTİ RAPORU

DOM XSS in document.write sink using source location.search

PortSwigger Web Security Academy Laboratuvarı

Hazırlayan: Şuheda EMLEK

Rapor Türü	Uygulama Güvenliği / Sızma Testi Raporu
Zafiyet Sınıfı	DOM tabanlı XSS
Laboratuvar Başlığı	document.write kaynak sunucu üzerinden hedef sunucuda DOM XSS saldırısı - location.search
Etkilenen Bileşen	Arama sorgusu izleme mekanizması
Temel Sink	document.write
Durum	Başarıyla doğrulandı / Solved

İçindekiler

1. Yönetici Özeti
2. Testin Amacı ve Kapsamı
3. Zafiyetin Teknik Açıklaması
4. Test Metodolojisi
5. Adım Adım İstismar Süreci
6. Kanıt Ekran Görüntüleri
7. Etki Analizi
8. Risk Değerlendirmesi
9. Önerilen Düzeltmeler
10. Sonuç

1. Yönetici Özeti

Bu çalışma, PortSwigger Web Security Academy ortamında yer alan DOM XSS laboratuvarının profesyonel raporlanması amacıyla hazırlanmıştır. İnceleme konusu olan uygulama, arama sorgusunu sayfa içerisine yazarken document.write fonksiyonunu kullanmaktadır.

Arama parametresi location.search kaynağı üzerinden kontrol edilebildiği için, uygulama kullanıcıdan gelen değeri güvenli biçimde ayrıştırmadan DOM içeriğine yerleştirmektedir. Bu davranış, uygun bir payload ile HTML bağlamından çıkılmasına ve JavaScript çalıştırılmasına imkân vermektedir.

Test sırasında önce rastgele bir alfanümerik değer ile veri akış yolu gözlemlenmiş, ardından Developer Tools yardımıyla bu verinin img src özelliği içine yazıldığı doğrulanmıştır. Son aşamada öznitelikten çıkış yapacak payload uygulanmış ve alert fonksiyonunun çalıştığı, bunun sonucunda laboratuvarın solved durumuna geçtiği kayıt altına alınmıştır.

2. Testin Amacı ve Kapsamı

Testin amacı, arama sorgusundan gelen kullanıcı girdisinin DOM içinde hangi bağlamda kullanıldığını belirlemek ve document.write sink üzerinden DOM tabanlı XSS istismarının mümkün olup olmadığını doğrulamaktır.

Kapsam Unsuru	Açıklama
Hedef sayfa	Blog arama sonuçları sayfası
Kontrol edilen kaynak	URL içindeki location.search parametresi
Veri yazma noktası	document.write sink
İstismar yaklaşımı	img src özniteliği içinden HTML bağlamına kaçış
Başarı kriteri	alert penceresinin açılması ve lab durumunun solved olması

3. Zafiyetin Teknik Açıklaması

DOM tabanlı XSS, kullanıcı girdisinin sunucu yerine istemci tarafında işlenmesi sırasında ortaya çıkar. Burada tehlikeli nokta, girdinin güvensiz bir JavaScript sink fonksiyonuna aktarılmasıdır.

Bu laboratuvarda document.write ile sayfaya HTML yazdırılmaktadır. Kaynak olarak ise location.search kullanılmaktadır. Arama terimi URL üzerinden değiştirilebildiği için saldırgan bu değeri kontrol edebilir.

Arama değerinin img src özniteliği içinde kullanılması, ilk bakışta doğrudan script çalıştırmayı engelliyor gibi görünse de, çift tırnak karakteri ile öznitelikten çıkış yapıp yeni bir etiket eklenerek payload çalıştırılabilir. Bu nedenle mesele sadece girdinin sayfada görünmesi değil, hangi bağlam içinde ve hangi sink aracılığıyla kullanıldığıdır.

4. Test Metodolojisi

Aşama	Gerçekleştirilen İşlem	Beklenen Çıktı
Keşif	Arama kutusuna rastgele alfanümerik değer girildi.	Değerin sayfada nasıl kullanıldığı gözlemlendi.
Kaynak-sink analizi	Developer Tools ile DOM incelendi.	Arama değerinin img src içine yazıldığı doğrulandı.
Payload geliştirme	Öznitelikten çıkış yapacak XSS girdisi oluşturuldu.	Yeni bir HTML etiketi enjekte edilmesi hedeflendi.
Doğrulama	Payload URL üzerinden çalıştırıldı.	alert penceresi ve solved durumu görüldü.

5. Adım Adım İstismar Süreci

Adım 1 - Başlangıç durumunun doğrulanması

Hedef laboratuvar açıldı. Sayfanın üst kısmında laboratuvar başlığı DOM XSS in document.write sink using source location.search olarak görüldü. Sağ üstte yer alan durum alanında lab'ın Not solved olduğu kaydedildi. Bu ekran, testin doğru hedef üzerinde başlatıldığını göstermektedir.

Adım 2 - Rastgele arama değeri ile veri akış yolunun izlenmesi

Arama kutusuna se04 gibi rastgele bir alfanümerik değer girildi. Sonuç sayfasında bu değer arama sonuc başlığında görüldüğü tespit edildi. Bu adım, kullanıcı girdisinin istemci tarafında sayfaya yansıtıldığını göstermektedir.

Adım 3 - Developer Tools ile bağlam analizi

Sayfa üzerinde sağ tik yapılarak inceleme araçları açıldı. Elements paneli üzerinde arama değerinin img src ifadesi içinde tracker.gif?searchTerms=se04 biçiminde yerleştirildiği görüldü. Bu bulgu, kontrollü verinin öznitelik bağlamına yazıldığını ve payload'ın bu bağlamdan kaçması gerektiğini ortaya koymuştur.

Adım 4 - Öznitelikten kaçış payload'ının hazırlanması

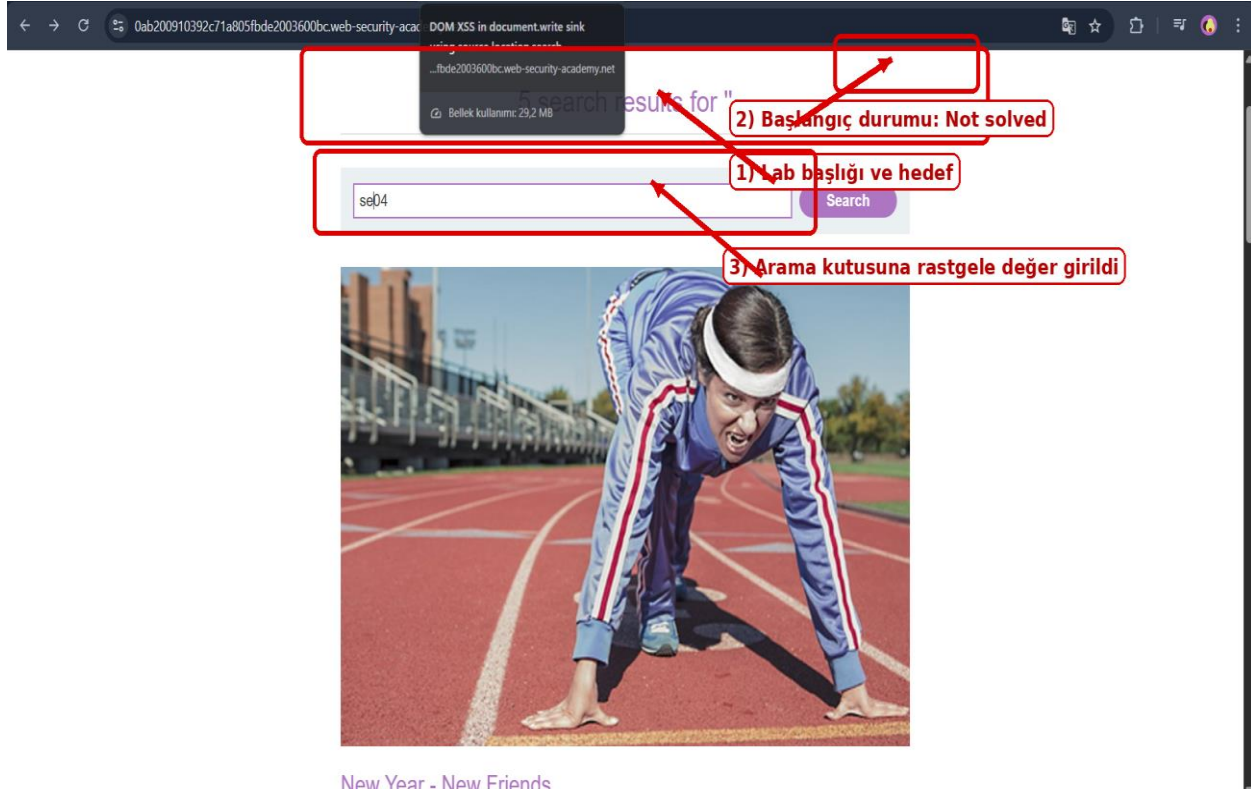
img src özelliği içine yazılan değerden çıkmak amacıyla başlangıçtaki çift tırnak kapatıldı ve ardından svg etiketi enjekte edildi. Kullanılan payload, onload olayında alert fonksiyonunu tetikleyecek şekilde tasarlandı. Böylece yeni HTML düğümü DOM'a eklenirken JavaScript çalıştırılması hedeflendi.

Adım 5 - XSS'nin tetiklenmesi ve kanıtlanması

Payload çalıştırıldığında tarayıcı üzerinde alert penceresi açıldı. Bu durum, kullanıcı kontrollü verinin DOM'a tehlikeli şekilde yerleştirildiğini ve XSS'nin başarıyla istismar edildiğini göstermektedir. Son ekran görüntüsünde laboratuvar solved durumuna geçmiştir.

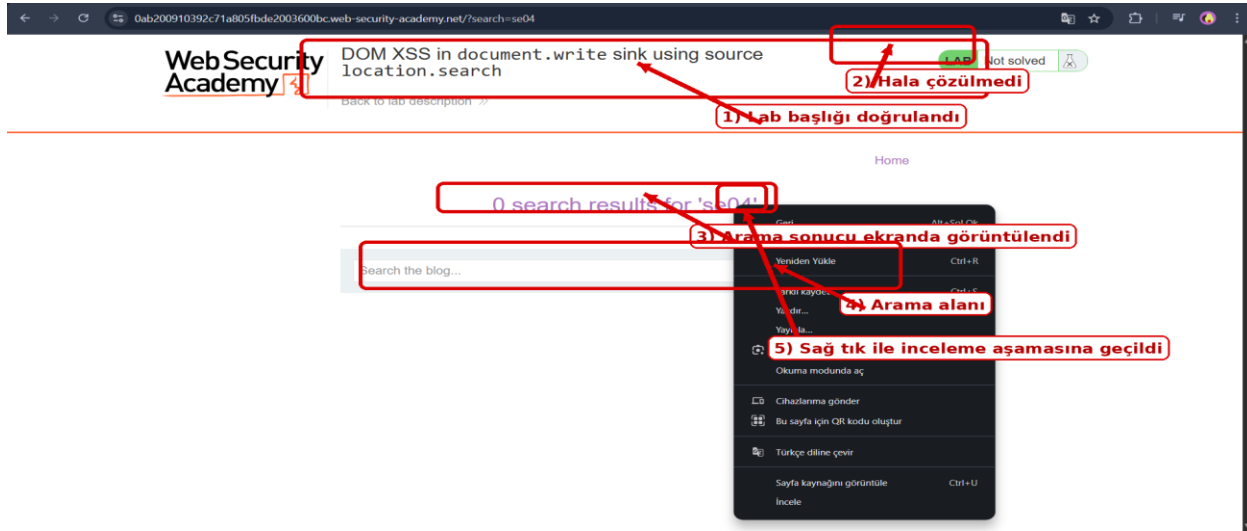
6. Kanıt Ekran Görüntüleri

Şekil 1 - Başlangıç sayfası ve ilk arama denemesi



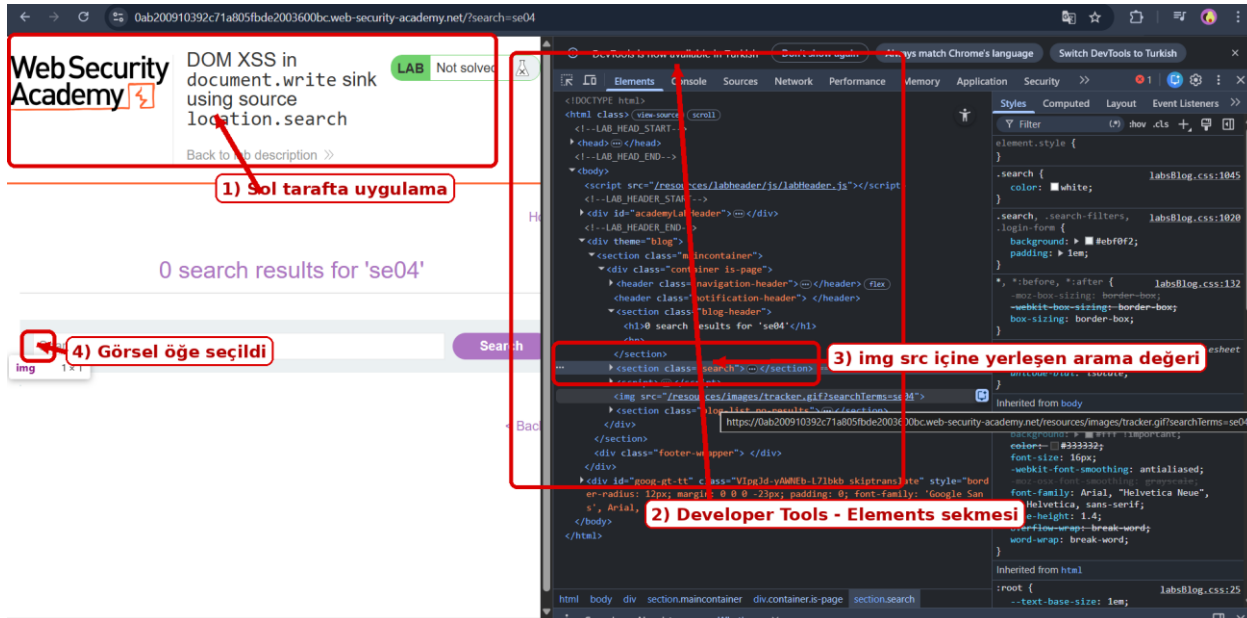
Açıklama: Kırmızı işaretlemeler ile laboratuvar başlığı, başlangıç durumu ve rastgele değer arama kutusuna girildiği bölüm vurgulanmıştır. Bu sayfa testin hangi hedefte başlatıldığını göstermektedir.

Şekil 2 - Arama sonucu ve inceleme aşamasına geçiş



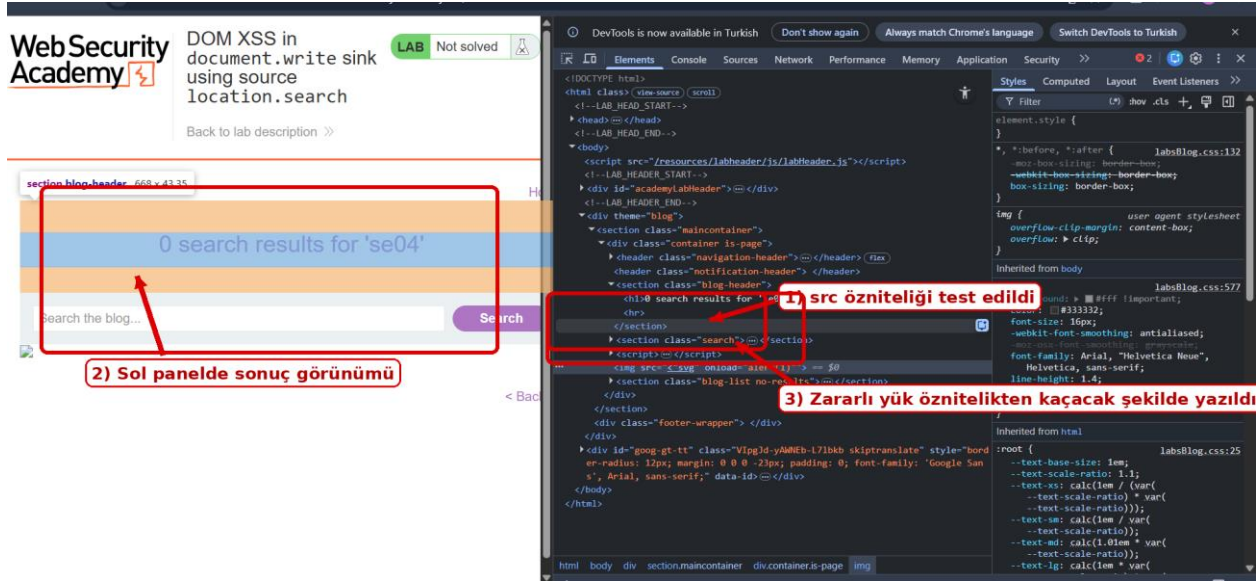
Açıklama: Rastgele değerın sonuçta ekrana yansıdığı görülmektedir. Bu adımdan sonra geliştirici araçları ile DOM bağlamı analiz edilmiş ve istismar yol haritası belirlenmiştir.

Şekil 3 - img src bağlamının doğrulanması



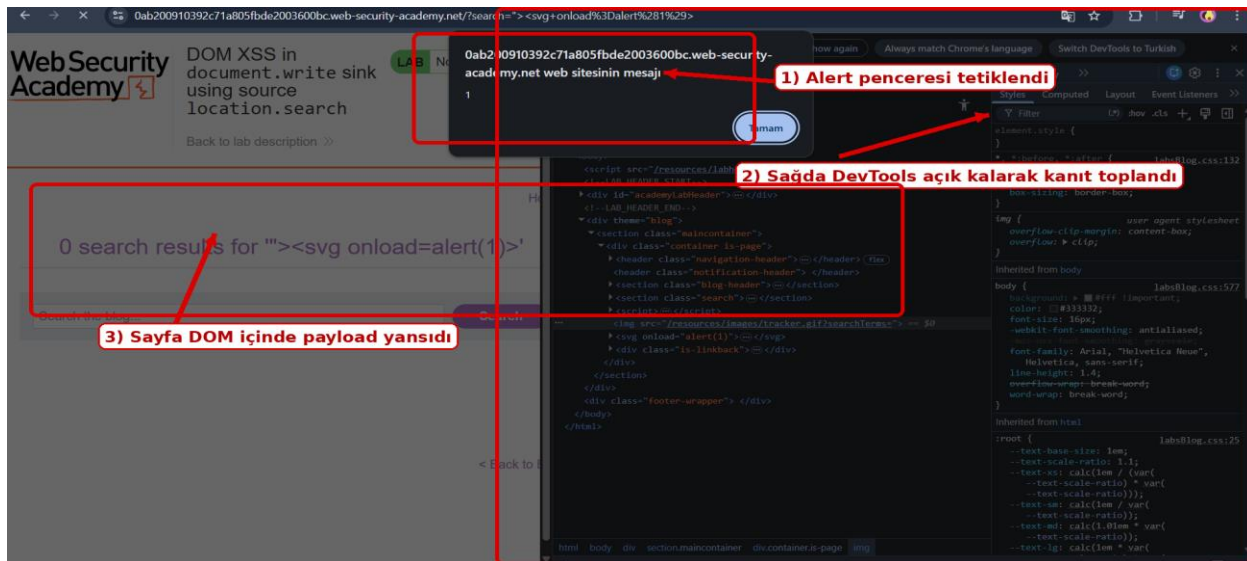
Açıklama: Developer Tools Elements panelinde arama değerinin img src özniteliği içerisine yerleştirildiği net şekilde görülmektedir. Bu kanıt, payload'ın neden öznitelikten kaçacak biçimde kurulması gerektiğini açıklamaktadır.

Şekil 4 - Payload'ın DOM üzerinde test edilmesi



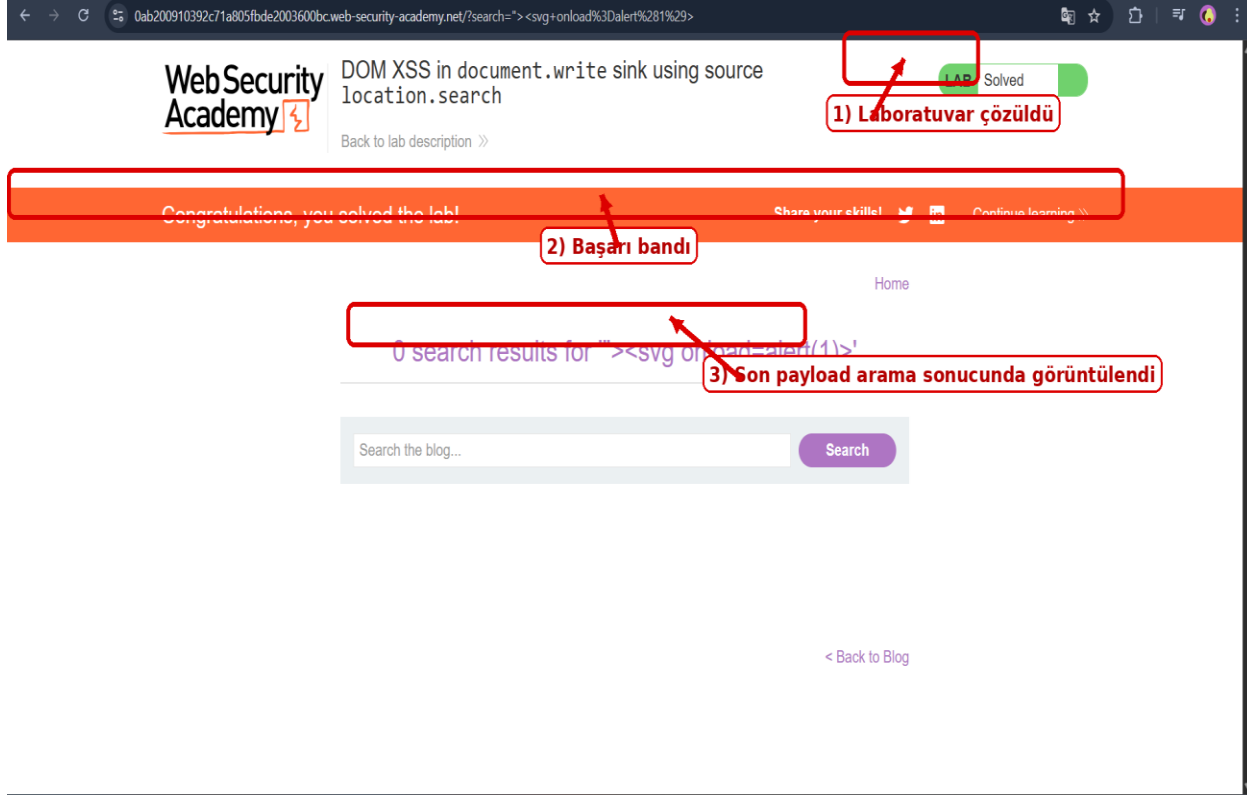
Açıklama: Öznelikten çıkışı sağlayan zararlı girdi DOM içerisinde gösterilmektedir. Bu görüntü, istismar kodunun yapısını ve hangi noktaya yerleştirildiğini belgelemektedir.

Şekil 5 - Alert penceresi ile istismarın kanıtlanması



Açıklama: Payload çalıştıktan sonra alert penceresi açılmış ve DOM üzerinde enjekte edilen etiket görünür hale gelmiştir. Bu aşama, zafiyetin pratik olarak istismar edildiğini göstermektedir.

Şekil 6 - Son durum ve laboratuvarın çözülmesi



Açıklama: Başarı bandı ve solved ibaresi görülmektedir. Bu son görüntü, testin başarıyla tamamlandığını ve laboratuvar gereksiniminin yerine getirildiğini kanıtlamaktadır.

7. Etki Analizi

Bu zafiyet, istemci tarafında keyfi JavaScript çalıştırılmasına olanak vermektedir. Gerçek bir uygulamada böyle bir açık aşağıdaki etkileri doğurabilir:

- Kurban kullanıcının tarayıcısında oturum bilgilerine erişmeye yönelik scriptlerin çalıştırılması
- Sayfa içeriğinin değiştirilmesi ve kullanıcının sahte formlara veya zararlı sitelere yönlendirilmesi
- Kullanıcı adına istek gönderilmesi ve istemci tarafı işlem akışının manipüle edilmesi
- Güven ilişkisinin kötüye kullanılarak kimlik avı ve dolandırıcılık senaryolarının kurulması

8. Risk Değerlendirmesi

Kriter	Değerlendirme
Zafiyet türü	DOM XSS
Etkilenen bileşen	Arama sorgusu izleme ve DOM yazdırma akışı
Saldırı zorluğu	Düşük
Etkilenen kullanıcılar	Manipüle edilmiş URL'yi açan tüm kullanıcılar
İş etkisi	Orta - Yüksek
Genel risk seviyesi	Yüksek

9. Önerilen Düzeltmeler

- location.search gibi kontrol edilebilir veriler doğrudan document.write gibi tehlikeli sink fonksiyonlarına aktarılmamalıdır.
- Kullanıcı girdileri HTML bağlamına yerleştirilmeden önce bağlama uygun encode edilmelidir.
- document.write yerine güvenli DOM API'leri tercih edilmelidir. Örneğin textContent veya güvenli nitelik atama mekanizmaları kullanılabilir.
- Uygulamada istemci tarafı güvenlik denetimleri yapılmalı, kaynak ve sink akışları düzenli olarak gözden geçirilmelidir.
- İçerik Güvenlik Politikası (CSP) uygulanarak script çalıştırma olasılığı ek katmanla sınırlandırılmalıdır.

10. Sonuç

Gerçekleştirilen test sonucunda, hedef uygulamanın arama sorgusu izleme işlevinde DOM tabanlı XSS zafiyeti bulunduğu başarıyla doğrulanmıştır.

location.search kaynağından gelen veri, document.write sink üzerinden güvensiz şekilde sayfaya yazdırılmış; bu da öznitelik bağlamından kaçış yapılarak alert fonksiyonunun çalıştırılmasına imkân vermiştir. Ekran görüntüleri, adım adım metodoloji ve sonuç ekranları birlikte değerlendirildiğinde, laboratuvarın hem teknik hem de kanıtsal olarak başarıyla tamamlandığı açıkça görülmektedir.